



الهيئة الوطنية
للأمن السيبراني
National Cybersecurity Authority

المتطلبات الفنية لمقدمي خدمات مركز عمليات الأمن السيبراني المُدار

Technical Requirements for Managed SOC Service Providers
(TRMSOC-1:2024)

إشارة المشاركة: أخضر

تصنيف الوثيقة: عام

بسم الله الرحمن الرحيم

بروتوكول الإشارة الضوئية (TLP):

يستخدم هذا البروتوكول على نطاق واسع في العالم وهناك أربعة ألوان (إشارات ضوئية):

أحمر – شخصي وسري للمستلم فقط



المستلم لا يحق له مشاركة المصنف بالإشارة الحمراء مع أي فرد، سواء أكان ذلك من داخل الجهة أم خارجها؛ خارج النطاق المحدد للاستلام.

برتقالي – مشاركة محدودة



المستلم يمكنه مشاركة المعلومات في الجهة نفسها مع الأشخاص المعنيين فحسب. ومن يتطلب الأمر منه اتخاذ إجراء يخص المعلومة.

أخضر – مشاركة في نفس المجتمع



المستلم يمكنه مشاركة المعلومات مع آخرين في الجهة نفسها، أو جهة أخرى على علاقة معهم أو في القطاع نفسه؛ ولا يسمح بتبادلها أو نشرها من خلال القنوات العامة.

أبيض – غير محدود



قائمة المحتويات

الصفحة

المقدمة ٤

التعريفات..... ٥

الهدف من المتطلبات الفنية..... ٨

نطاق المتطلبات الفنية..... ٩

المتطلبات الفنية لمقدمي خدمات مركز عمليات الأمن السيبراني المُدار ٩

أحكام عامة..... ٢٠

الملاحق..... ٢١

١. المقدمة

تعد الهيئة الوطنية للأمن السيبراني؛ الجهة المختصة بالأمن السيبراني في المملكة، والمرجع الوطني في جميع شؤونه، وتهدف إلى تعزيزه؛ حمايةً للمصالح الحيوية للدولة، وأمنها الوطني، والبنى التحتية الحساسة، والقطاعات ذات الأولوية، والخدمات والأنشطة الحكومية؛ وذلك وفق تنظيمها الصادر بموجب الأمر الملكي الكريم ذي الرقم (٦٨٠١) الصادر في ١٤٣٩/٢/١١هـ، وتشمل اختصاصات الهيئة ومهامها -دون حصر- وضع السياسات وآليات الحوكمة، والأطر، والمعايير، والضوابط، والإرشادات المتعلقة بالأمن السيبراني، وتعميمها على الجهات ذات العلاقة، ومتابعة الالتزام بها، وتحديثها. بالإضافة إلى الترخيص بمزاولة الأفراد والجهات غير الحكومية، للأنشطة والعمليات المتعلقة بالأمن السيبراني؛ التي تحددها الهيئة. وتشمل اختصاصات ومهام الهيئة كذلك؛ تحفيز نمو قطاع الأمن السيبراني في المملكة، وتشجيع الابتكار والاستثمار فيه.

٢. التعريفات

يكون للمصطلحات المستخدمة في هذه المتطلبات الفنية المعاني المقابلة لها؛ ما لم يقتض السياق خلاف ذلك:

المصطلح	التعريف
الهيئة	الهيئة الوطنية للأمن السيبراني.
الجهات	هي الجهات الحكومية، أو الخاصة الربحية، أو غير الربحية، أو أي شكل آخر من أشكال الجهات.
الإطار	الإطار التنظيمي لترخيص تقديم خدمات مركز عمليات الأمن السيبراني المُدار، الصادر عن الهيئة.
السياسة	السياسة الوطنية لمراكز عمليات الأمن السيبراني المُدارة، الصادرة عن الهيئة.
البنية التحتية الوطنية الحساسة	هي تلك العناصر الأساسية للبنية التحتية، أي (الأصول، والمرافق، والنظم، والشبكات، والعمليات، والعاملون الأساسيون الذين يقومون بتشغيلها ومعالجتها) والتي قد يؤدي فقدانها أو تعرضها لانتهاكات أمنية إلى: ١. أثر سلبي كبير على توافر الخدمات الأساسية، أو تكاملها، أو تسليمها، بما في ذلك الخدمات التي يمكن أن تؤدي، في حال تعرضت سلامتها للخطر؛ إلى خسائر كبيرة في الممتلكات و/ أو الأرواح و/ أو الإصابات، مع مراعاة الآثار الاقتصادية و/أو الاجتماعية الكبيرة. ٢. تأثير كبير على الأمن الوطني و/ أو الدفاع الوطني و/ أو اقتصاد الدولة أو مقدراتها الوطنية.
مركز عمليات الأمن السيبراني	هو مركز يقدم خدمات العمليات، المتعلقة بمراقبة أحداث الأمن السيبراني في المنظومة التقنية للجهة، وتؤدي إلى اكتشاف التهديدات السيبرانية، ومعرفة كيفية حدوثها، وتقديم التوصيات في كيفية معالجتها، واتخاذ الإجراءات اللازمة لاحتوائها.
خدمات مركز عمليات الأمن السيبراني المُدار	هي الخدمات التي تحصل عليها الجهة المستفيدة من مقدم الخدمة، بهدف مراقبة أحداث الأمن السيبراني في المنظومة التقنية لديها؛ لاكتشاف التهديدات السيبرانية، ومعرفة كيفية حدوثها، وتقديم التوصيات في كيفية معالجتها، ليتم تطبيقها من قبل الجهة المستفيدة، وتشمل هذه الخدمات؛ العمليات، وفرق العمل، والأنظمة ذات الصلة، وغيرها.
الترخيص	هو وثيقة تُصدرها الهيئة؛ تسمح بموجبها لمقدم الخدمة بممارسة نشاط تقديم خدمات مركز عمليات الأمن السيبراني المُدار في المملكة؛ وذلك وفقاً لما تحدده الهيئة.
مقدم الخدمة	الجهة المرخصة من الهيئة، لتقديم خدمات مركز عمليات الأمن السيبراني المُدار في المملكة؛ وفقاً للإطار.

المصطلح	التعريف
مركز عمليات الأمن السيبراني المُدار	مركز يتبع لمقدم الخدمة، ويكون تحت كامل مسؤوليته وخارج مقر الجهة المستفيدة، ويهدف إلى مراقبة حالة أحداث الأمن السيبراني في المنظومة التقنية للجهة المستفيدة من خلال تقديم خدمة أو أكثر من خدمات مراكز عمليات الأمن السيبراني؛ وذلك ضمن نطاق عمل الخدمة المتفق عليه بين مقدم الخدمة والجهة المستفيدة، وفقاً لما هو موضح في الإطار التنظيمي لترخيص تقديم خدمات مركز عمليات الأمن السيبراني.
الجهة المستفيدة	هي الجهة التي تتعاقد مع مقدم الخدمة، بهدف الحصول على خدمات مركز عمليات الأمن السيبراني المُدار.
شهادة التأهيل	هي وثيقة تصدرها الهيئة لشخص طبيعي تقضي بأهليته للعمل محلاً في مراكز عمليات الأمن السيبراني المُدارة لدى مقدم الخدمة.
محلل مركز عمليات الأمن السيبراني المُدار	أي شخص طبيعي، حاصل على شهادة تأهيل، للعمل محلاً في مركز عمليات الأمن السيبراني المُدار.
مقدم خدمة الحوسبة السحابية	أي شخص طبيعي أو معنوي (مثل الشركات) مرخص من الجهة المختصة في المملكة بتقديم خدمات الحوسبة السحابية إلى العموم، سواء أكان ذلك بشكل مباشر، أم غير مباشر؛ من خلال مراكز بيانات (سواء أكانت داخل المملكة أم خارجها) ويديرها بنفسه بشكل كلي أو جزئي.
حدث أمن سيبراني	حدث ذو علاقة بحالة الأمن السيبراني الخاصة بشبكة، أو نظام، أو خدمة، أو بيانات، أو أي جهاز تقني آخر.
ضوابط الأمن السيبراني الصادرة عن الهيئة	هي القواعد المتعلقة بالحد الأدنى من متطلبات الأمن السيبراني، وتشمل، على سبيل المثال لا الحصر، سياسات وإجراءات وبروتوكولات الأمن السيبراني الصادرة عن الهيئة.
برنامج الأمن السيبراني لمقدم الخدمة	يشير إلى مجموعة الوثائق، التي تحتوي على تفاصيل عن خطط مقدم الخدمة وإجراءاته؛ المتعلقة بالحفاظ على الأمن السيبراني، والتصدي للانتهاكات الأمنية، والنسخ الاحتياطي للبيانات، واسترجاع البيانات أو إتلافها عقب انتهاء العقد.
المستوى الأول Tier 1	مستوى ترخيص تقديم خدمة يعطى من قبل الهيئة لمقدم الخدمة والذي يسمح لمقدم الخدمة تقديم خدمات مركز عمليات الأمن السيبراني المُدار لجميع الجهات؛ بما في ذلك الجهات الحكومية، والجهات التي تمتلك بنية تحتية وطنية حساسة، أو تقوم بتشغيلها، أو استضافتها.
المستوى الثاني Tier 2	مستوى ترخيص تقديم خدمة يعطى من قبل الهيئة لمقدم الخدمة والذي يسمح لمقدم الخدمة تقديم خدمات مركز عمليات الأمن السيبراني المُدار لأي جهة؛ عدا الجهات الحكومية، والجهات التي تمتلك بنية تحتية وطنية حساسة، أو تقوم بتشغيلها، أو استضافتها.

المصطلح	التعريف
البنية التحتية لمركز العمليات الأمنية	هي مجموعة من الأجهزة والمعدات اللازمة لاستضافة وتشغيل وتقديم خدمات مركز عمليات الأمن السيبراني المُدار، ويشمل ذلك، على سبيل المثال لا الحصر، المرافق وأنظمة التبريد وإمدادات الطاقة وأنظمة الحماية من الحرائق وإخمادها وشبكات الكمبيوتر والأجهزة والبرمجيات والبرامج الوسيطة والبرامج الثابتة وقواعد البيانات ومحطات العمل والمكونات الأخرى التي تتكون منها هذه البنية التحتية.
نظام تقنية المعلومات	التقنيات التي تُعنى بتطوير الأنظمة الحاسوبية والبرمجيات والشبكات وصيانتها واستخدامها في عمليات معالجة البيانات وتوزيعها. وتتمثل هذه التقنيات في الأنظمة الإدارية، وأنظمة الأعمال في الجهة.
التقنية التشغيلية	مجموعة من المكونات التي تشمل أجهزة الشبكة، وأجهزة الحاسب والخوادم، وأجهزة الأمن السيبراني، ومعدات البنية التحتية، والتطبيقات التي تدعم عمليات التشغيل والصيانة والمراقبة، الأمن السيبراني للبيئات التشغيلية، وأنظمة التحكم الصناعي (ICS/OT).
سجل الأحداث	سجل يتم إنشاؤه من أنظمة تقنية المعلومات أو التقنيات التشغيلية لتوثيق معلومات خاصة بحدث معين تم على النظام أو التقنية، تشمل هذه المعلومات بيانات أساسية مثل اسم النظام ووقت الحدث وتفاصيله.
بيانات مراقبة الأمن السيبراني	البيانات المولدة من أنظمة تقنية المعلومات أو التقنيات التشغيلية التي يمكن معالجتها وتحليلها لتقديم خدمة مركز عمليات الأمن السيبراني المُدار. تتضمن هذه البيانات سجلات الأحداث والبيانات الوصفية وبيانات الشبكة مثل بيانات حركة المرور وحزم البيانات.
حادثة سيبرانية	الحدث الذي يؤثر على سرية أو سلامة أو توافرية أنظمة تقنية المعلومات أو التقنيات التشغيلية أو المعلومات التي تعالجها أو تخزينها أو نقلها.
بوابة حصين	البوابة الوطنية لخدمات الأمن السيبراني التابعة للهيئة.

٣. الهدف من المتطلبات الفنية

استناداً على الفقرة (١٠) من البند (٩) من الإطار التنظيمي لترخيص تقديم خدمات مركز عمليات الأمن السيبراني المُدار والتي نصت على أنه "تعد الملاحق الواردة في هذا الإطار؛ بالإضافة إلى وثيقة (المتطلبات الفنية لمقدمي خدمات مركز عمليات الأمن السيبراني المُدار) جزءاً من هذا الإطار، ويتم قراءتها والعمل بها كوثيقة واحدة"، فقد تم إعداد هذه الوثيقة لتحديد المتطلبات الفنية التي يجب على المرخص له التقيد بها حين تقديم الخدمات المرخص بها وفقاً لمستوى ترخيص مقدمي خدمات مركز عمليات الأمن السيبراني المُدار لتحقيق الأهداف المرجوة من الإطار والسياسة الوطنية لمراكز عمليات الأمن السيبراني المُدارة. وتطبق هذه المتطلبات على كافة مقدمي الخدمات بما يمكنهم من تقديم الخدمات في المملكة وفقاً لما جاء في الإطار والالتزامات الواردة فيه.

٤. نطاق الوثيقة

يجب على مقدم الخدمة الالتزام بالمتطلبات ذات العلاقة المنصوص عليها في هذه المتطلبات الفنية ليتمكن من تقديم تلك الخدمات في المملكة وفقاً للإطار التنظيمي لتراخيص خدمات مركز عمليات الأمن السيبراني المُدار.

٥. المتطلبات الفنية لمقدمي خدمات مركز عمليات الأمن السيبراني المُدار

حددت الهيئة نموذجاً من مستويين لترخيص مقدمي خدمات مركز عمليات الأمن السيبراني المُدار من أجل تمكين نمو السوق وضمان توفير أفضل قدرات المراقبة لدى الجهات. حيث يجب على مقدم طلب الحصول على ترخيص تقديم خدمات مراكز عمليات الأمن السيبراني المُدارة استيفاء جميع المتطلبات الرئيسية والتي تركز على العمليات والتقنيات والأفراد.

تراعي المتطلبات التالية الركائز الرئيسية الثلاثة: العمليات والتقنيات والأفراد.

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
١	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إعداد دليل للخدمة يشمل على الأقل العناصر التالية لكل خدمة فرعية: الوصف، اتفاقية مستوى الخدمة، نطاق التغطية، إجراءات تقديم الخدمة وإيقافها، المتطلبات الأساسية، مخططات سير العمل، ساعات التشغيل، الأنشطة، مصفوفة توزيع المسؤوليات، والتفاعلات الرئيسية. The Managed SOC Service Provider to develop a SOC Service Catalogue which includes at minimum, the following elements for each sub-service offered: description, service level agreement (SLA), coverage, onboarding and off boarding procedures, prerequisites, workflows, hours of operation, activities, RACI matrix and key interactions. للحصول على قائمة مرجعية للعمليات، يرجى الرجوع إلى الملحق أ-١: العمليات	مطلوب	مطلوب
٢	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قابلية التشغيل البيني للعمليات، بمعنى أن تكون العمليات والإجراءات متكاملة في نقاط وعناصر معينة مراعية التسلسل المنطقي لبيانات مراقبة الأمن السيبراني ومراحل تقدم الخدمة من المراقبة والكشف إلى التحليل والتحقيق دون وجود أي قصور أو فجوة في تسلسل العمليات والإجراءات مما يتيح تحقيق القيمة بكفاءة. The Managed SOC service provider to demonstrate process interoperability – processes and procedures integrated at certain	مطلوب	موصى به

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	points and elements considering the logical sequence of cybersecurity telemetry and service progress stages from monitoring and detection to analysis and investigation, without any failure or gaps in the sequence of processes and procedures, which enable efficient value delivery. للحصول على قائمة مرجعية للعمليات، يرجى الرجوع إلى الملحق أ-١: العمليات		
٣	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على تشغيل الخدمات على مدار الساعة طوال أيام الأسبوع وعلى مدار العام وفقاً لاتفاقية مستوى الخدمة والالتزامات التعاقدية. The Managed SOC service provider to demonstrate ability to operate the services 24/7/365 in accordance with SLA and contractual obligations.	مطلوب	مطلوب جزئياً (خلال أوقات العمل كحد أدنى)
٤	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إبرام اتفاقيات تعاقدية لتقديم خدمات دعم وصيانة على مدار الساعة مع مصنعي التقنيات المستخدمة في تقديم الخدمة. The Managed SOC service provider to demonstrate support and maintenance contractual agreements with vendors for core technology platforms. للحصول على قائمة غير شاملة بالتقنيات التي قد تدعم خدمة مركز عمليات الأمن السيبراني المُدار، يرجى الرجوع إلى الملحق أ-٢: التقنيات	مطلوب	مطلوب جزئياً (خلال أوقات العمل كحد أدنى)
٥	بالنسبة للقدرات التي يتعين توفيرها عبر خدمات الحوسبة السحابية، يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار الاشتراك مع مقدم خدمات حوسبة سحابية مرخص (CSP) في فئة محددة. For cloud-delivered capabilities, the Managed SOC Service Provider to ensure subscription with a licensed cloud service provider (CSP) for a specific class. For more details, please refer to https://www.cst.gov.sa/en/RulesandSystems/RegulatoryDocuments/Pages/CCRF.aspx	الفئة "ج" ١ كحد أدنى	الفئة "أ" ١ كحد أدنى
٦	بالنسبة للقدرات التي يتم توفيرها عبر خدمات الحوسبة السحابية، يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار الالتزام بضوابط الأمن السيبراني للحوسبة السحابية الصادرة عن الهيئة (CCC – 1: 2020).	مطلوب	مطلوب

^١ بحسب تصنيف الفئات المحددة لدى الجهة المختصة بالترخيص في المملكة لتقديم خدمات الحوسبة السحابية

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	For cloud-delivered capabilities, the Managed SOC service provider to comply with NCA Cloud Cybersecurity Controls (CCC – 1: 2020).		
٧	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار الالتزام التام بالمتطلبات التنظيمية الصادرة عن الهيئة فيما يتعلق بمشاركة معلومات الأمن السيبراني، ويشمل ذلك على سبيل المثال لا الحصر: • الإبلاغ عن التنبيهات الأمنية السيبرانية طبقاً لإرشادات الهيئة بهذا الشأن لضمان ارسال الاشعارات إلى الجهات المستفيدة والهيئة من خلال بوابة حصين. • استيعاب وتوظيف المعلومات المقدمة من الهيئة والجهات المستفيدة. بما يتعلق بالمعلومات الواردة من الهيئة من خلال بوابة حصين، يكون ضمن المدة الزمنية المحددة من قبلها. The Managed SOC service provider to fully comply with regulatory requirements issued by NCA related to cybersecurity information sharing, including but not limited to: • Reporting cybersecurity alerts in accordance with NCA's instructions in this regard to ensure that notifications are sent to Service Beneficiaries and NCA through Haseen portal. • Ingest/act upon information provided by NCA or Service Beneficiary. Regarding the information received from NCA through Haseen portal, it must be within the period determined by NCA.	مطلوب	مطلوب
٨	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار ربط التهديدات المرصودة بالأطر الرائدة في مجال الكشف عن الهجمات وغمجة التهديدات وتشمل إطار MITRE ATT&CK. The Managed SOC service provider to establish a use case framework with clear detection logic, mapped to leading platforms including MITRE ATT&CK.	مطلوب	موصى به
٩	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار وضع وتنفيذ منهجية لتطوير وضبط مستمر لحالات الاستخدام وتحسينها بما في ذلك قواعد الكشف لتعزيز الاكتشاف والحد من التنبيهات الزائفة The Managed SOC service provider to establish a methodology to continuously create and tune use-cases and correlation rules to augment detection and reduce false-positive alerts.	مطلوب؛ بشكل شهري	مطلوب؛ بشكل ربع سنوي
١٠	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار الالتزام التام بالمتطلبات التنظيمية الصادرة عن الهيئة فيما يتعلق بإدارة حوادث الأمن السيبراني والاستجابة	مطلوب	مطلوب

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	لها، وتشمل على سبيل المثال لا الحصر: إبلاغ الهيئة والجهات المستفيدة على الفور بالحوادث والمعلومات ذات العلاقة بالحادثة السيبرانية فور تصنيف التنبيه/التنبيهات الأمنية على أنها حادثة، ويكون تبليغ الهيئة من خلال بوابة حصين. The Managed SOC service provider to fully comply with with regulatory requirements issued by NCA related to cybersecurity incident management, including but not limited to: immediately notifying NCA and Service beneficiaries of cybersecurity incidents and their related information upon classifying security alert(s) as an incident. NCA notification shall be through the Haseen portal.		
١١	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إعداد الأدلة الإرشادية لتحديد الإجراءات المحددة مسبقاً للتعامل مع التهديدات. The Managed SOC Service Provider to establish pre-defined response playbooks for threats.	مطلوب	مطلوب
١٢	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار وضع منهجية لاحتواء الحوادث السيبرانية فور حدوثها، على أن تشمل حصر الأصول المتأثرة وتحديد تصنيفها وتقديم التوصيات الأولية بشأن الإجراءات المطلوب اتخاذها من قبل الجهات المستفيدة و/أو مقدم الخدمة -عند طلب الهيئة القيام بذلك- لاحتواء الحادثة السيبرانية وإيقاف أضرارها والحد منها، وتصميم التدابير المضادة، وتحديد الموارد التقديرية المطلوبة والوقت اللازم للتنفيذ، وآليات متابعة تنفيذ التوصيات. The Managed SOC Service Provider to define a methodology to contain cyber incidents as soon as they occur, which must include inventorying the affected assets, determining their classification, and providing initial recommendations regarding the actions required to be taken by the service beneficiaries and/or the service provider – when requested by NCA - to contain the cyber incident, stopping and reducing their damage, designing countermeasures, determining the estimated resources required and the time required for implementation, and mechanisms for following up on the implementation of recommendations.	مطلوب	مطلوب
١٣	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته الفنية على الربط بين بيانات الأنظمة والحلول المختلفة وتبادلها وتحليلها والوصول إليها باستخدام تقنيات التنسيق والأتمتة. The Managed SOC Service Provider to demonstrate technical capability to connect, exchange, interpret and access data of	مطلوب	موصى به

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	different systems and solutions using orchestration and automation technologies. للحصول على قائمة غير شاملة بالتقنيات التي قد تدعم خدمة مركز عمليات الأمن السيبراني المُدار، يرجى الرجوع إلى الملحق أ-٢: التقنيات		
١٤	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار تطوير وتوفير بوابة خدمات تُتيح مجموعة من لوحات المتابعة والتقارير المختلفة للجهات المستفيدة من الخدمات حتى يمكنها الاطلاع على حالة الخدمات والمقاييس الرئيسية، بما في ذلك النماذج الخاصة بالخدمات. ويعتبر النوع الرئيسي من لوحات المتابعة المطلوبة، على سبيل المثال لا الحصر، ما يلي: ● لوحات متابعة حالة الخدمة ● لوحات متابعة على المستوى التنفيذي تسلط الضوء على حالة الالتزام بالمقاييس الرئيسية واتفاقية مستوى الخدمة ● لوحات متابعة تشغيلية تُتيح الاطلاع على المقاييس التشغيلية The Managed SOC Service Provider to build and avail a service portal that encompasses dashboards and reports for service beneficiaries providing visibility on service status and key metrics, including service-specific templates. Key type of dashboards illustrated should include, but not limited to: ● Service status dashboards ● Executive-level dashboards highlighting key metrics and SLA compliance posture ● Operational dashboards providing visibility on operational metrics	مطلوب	موصى به
١٥	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار توفير قدرات العرض المرئي للبيانات الحية للمستخدمين، ويشمل ذلك، على سبيل المثال لا الحصر، العرض المفصل للبيانات والرسومات البيانية والمخططات للبيانات التشغيلية والخدمية. The Managed SOC Service Provider to provide live data visualization including, but not limited to, detailed operational and service level graphs and charts to clients.	مطلوب	موصى به
١٦	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار بناء قدرات العزل المنطقي لبيانات الجهات المستفيدة من الخدمات. The Managed SOC Service Provider to establish logical isolation capabilities for service beneficiaries' data.	مطلوب	مطلوب

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
١٧	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على الاتلاف الآمن لبيانات مراقبة الأمن السيبراني الخاصة بالجهات المستفيدة وفقاً لضوابط الأمن السيبراني للبيانات الصادرة عن الهيئة. The Managed SOC Service Provider to demonstrate capability to securely dispose beneficiary cybersecurity telemetry records in accordance with NCA Data Cybersecurity Controls (DCC).	مطلوب	مطلوب
١٨	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على تحقيق التكامل الآمن بين حزم التقنيات وخدمات التحقق من الهوية والتفويض (على سبيل المثال بروتوكول LDAP، وبروتوكول OAuth، وبروتوكول Radius). The Managed SOC Service Provider to demonstrate technology stack secure integration capability with authentication and authorization services (for example LDAP, OAuth, Radius).	مطلوب	مطلوب
١٩	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على جمع ومشاركة المعلومات الخارجية بصورة آنية من خلال التكامل الآلي للمنصة المخصصة لذلك باستخدام معايير STIX/TAXII واستخدام API endpoints لإرسال واستقبال المعلومات ذات الصلة، ويشمل ذلك، على سبيل المثال لا الحصر، بيانات المراقبة السيبرانية والحوادث ومؤشرات التهديدات والتكتيكات والتقنيات والإجراءات. The Managed SOC Service Provider to demonstrate near-real time external information gathering and sharing capability through automated integration of a dedicated platform utilizing STIX/TAXII standards and the utilization of API endpoint to send or receive relevant information including, but not limited to, cybersecurity telemetry, incidents, threat indicators and TTPs.	مطلوب	موصى به
٢٠	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إنشاء وتوفير مركز عمليات أمن سيبراني مخصص ومرافق مادية وشبكات وبنية تحتية داعمة لتقديم الخدمات المُدارة، مع إتاحة القدرة على التأقلم مع متطلبات تقديم الخدمات والأمن وقابلية التوسع وغيرها من المتطلبات التنظيمية. The Managed SOC Service Provider to build and demonstrate a dedicated designated SOC and supporting physical facilities, networks and infrastructure for managed service delivery, adaptive to service delivery, security, scalability and other regulatory requirements.	مطلوب	مطلوب
٢١	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار التأكد من جمع ومراقبة، وتحليل سجلات الأحداث من مصادر السجلات وفقاً لملحق ب وملحق	مطلوب	مطلوب

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	ج، ويشمل ذلك، على سبيل المثال لا الحصر، الأجهزة الطرفية والتطبيقات وأجهزة الشبكة والأجهزة الأمنية. The Managed SOC Service Provider to ensure the collection, monitoring and analysis of logs from log sources in accordance to Appendix B and Appendix C including but not limited to endpoints, applications, network devices, and security devices. للحصول على قائمة غير شاملة بالتقنيات التي قد تدعم خدمة مركز عمليات الأمن السيبراني المُدار، يرجى الرجوع إلى الملحق أ-٢: التقنيات للحصول على الحد الأدنى من الأنظمة التي يلزم جمع السجلات منها، يرجى الرجوع إلى الملحق ج: الحد الأدنى لمتطلبات سياسة جمع الأحداث السيبرانية		
٢٢	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار جمع ومواءمة بيانات مراقبة الأمن السيبراني بشكل مركزي. The Managed SOC Service Provider to provide centralized collection, aggregation, and normalization of collected cybersecurity telemetry. للحصول على متطلبات سمات سجلات الأحداث، يرجى الرجوع إلى الملحق "ب" للحصول على الحد الأدنى لمتطلبات جمع بيانات مراقبة الأمن السيبراني لتفعيلها لدى المستخدمين، يرجى الرجوع إلى الملحق "ج"	مطلوب	مطلوب
٢٣	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار الاحتفاظ بسجلات الأحداث لمدة 18 شهر على الأقل وبحيث تكون سجلات الأحداث الخاصة بآخر ١٢ شهر محفوظة بشكل نشط - Active Storage - حيث يمكن البحث فيها بشكل مباشر والقيام بأعمال تصيد التهديدات. The Managed SOC Service Provider to ensure that logs are stored for not less than 18 months. While logs that are related to that the last 12 months are actively available - Active Storage - to enable direct search and threat hunting activities.	مطلوب	مطلوب
٢٤	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار التأكد من جمع ومراقبة وتحليل المعلومات الخاصة بتدفق البيانات على الشبكة، بما في ذلك على سبيل المثال لا الحصر، المعلومات عن حركة البيانات عبر الشبكة (NetFlow)، وبيانات JFlow، وبيانات IPFIX، وبيانات sFlow. The Managed SOC Service Provider to ensure the collection ,monitoring and anslsyis of network flows including but not limited to NetFlow, JFlow, IPFIX, and sFlow information.	مطلوب	مطلوب
٢٥	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار جمع ومراقبة وتحليل حزم بيانات الشبكة الهامة وفق ملحق ج مع مراعاة جمع وتخزين البيانات الخام	موصى به	موصى به

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	في البنية التحتية الخاصة بالجهة المستفيدة دون نقلها إلى الخارج ويتم تحليل وتخزين البيانات بعد عملية فك التشفير، عند الإمكان. The Managed SOC Service Provider to ensure the collection, monitoring and analysis of critical network packets as per Appendix C while collection and storage of raw data must be at the entity side without transferring externally. In addition, the analysis and storage is to be performed after SSL decryption/offloading where possible.		
٢٦	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار تطوير موصّلات وموزعات مخصصة للأمن السيبراني تدعم تفسير الصيغ المختلفة بيانات مراقبة الأمن السيبراني، ويشمل ذلك، على سبيل المثال لا الحصر، الصيغ والترميزات (XML, CSV, JSON, CEF, and LEEF). The Managed SOC Service Provider to develop custom cybersecurity telemetry connectors and parsers to support the different security event log format interpretation including but not limited to, XML, CSV, JSON, CEF, and LEEF. للحصول على متطلبات سمات سجلات الأحداث، يرجى الرجوع إلى الملحق "ب"	مطلوب	مطلوب
٢٧	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار دعم العديد من آليات جمع البيانات الآمنة، مثل البروتوكولات التي تشمل، على سبيل المثال لا الحصر، البروتوكولات (HTTPS, SCP, SFTP, WMI, syslog). The Managed SOC Service Provider to support multiple secure data collection mechanisms such as protocols including but not limited to syslog, WMI, SFTP, SCP, and HTTPS.	مطلوب	مطلوب
٢٨	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على الربط متعدد المراحل بين البيانات (إيجاد العلاقة بين الأحداث على مستويات مختلفة). The Managed SOC Service Provider to demonstrate capability for multi-stage correlation.	موصى به	موصى به
٢٩	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على إعداد موصّلات وموزعات مصممة خصيصاً لمراقبة وتحليل البيانات السيبرانية أداء شبكات الأمن السيبراني لربطها مع مصادر البيانات السيبرانية وتفسيرها. The Managed SOC Service Provider to demonstrate capability for the development of custom telemetry connectors and parsers to connect to and interpret different telemetry sources. للحصول على متطلبات سمات سجلات الأحداث، يرجى الرجوع إلى الملحق "ب"	مطلوب	موصى به

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	للحصول على الحد الأدنى لمتطلبات جمع بيانات مراقبة الأمن السيبراني لتفعيلها لدى المستفيدين، يرجى الرجوع إلى الملحق ج: الحد الأدنى من متطلبات جمع بيانات الأحداث السيبرانية		
٣٠	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على إزالة البيانات المكررة الناتجة من مصادر البيانات المختلفة. The Managed SOC Service Provider to demonstrate capability for automated deduplication of telemetry sources.	مطلوب	مطلوب
٣١	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار دعم عمليات البحث عن البيانات السيبرانية واكتشاف التهديدات السابقة وشبه الآنية وتصنيفها باستخدام التقنيات الملائمة لتحقيق التالي: ● وضع الفرضيات والتحقق منها من خلال تحليل الشبكات والأجهزة الطرفية ومجموعات البيانات للبحث عن التهديدات التي قد تكون تفادت الضوابط الحالية وقواعد اكتشاف التهديدات المطبقة ● البحث عن المؤشرات، بما في ذلك قيم التجزئة وعناوين بروتوكول الإنترنت وأسماء النطاقات ● البحث عن الآثار والأدوات والتقنيات المستخدمة من قبل المهاجمين على الأنظمة والشبكات The Managed SOC Service Provider to support searching, filtering and hunting activities in near real-time and historical cybersecurity telemetry using appropriate tools and expressions to achieve the following: ● Develop and validate hypothesis through analysis of networks, endpoints and datasets to hunt threats that may have evaded existing usecases and controls ● Hunt for indicators including hash values, IP addresses, and domain names ● Hunt for host and network artifacts, tools and attacker TTPs	مطلوب	مطلوب
٣٢	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار استخدام آليات كشف عن التهديدات السابقة وشبه الآنية مبنية على التالي: ● التوقييع والتحليل السلوكي بيانات مراقبة الأمن السيبراني للكشف عن الأنشطة الغريبة أو الخبيثة ● اكتشاف الحالات غير الطبيعية والقيم المتطرفة باستخدام الأساليب الإحصائية ومقارنتها مع خطوط الأساس المحددة	مطلوب	مطلوب

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	● استخدام المعلومات الاستباقية عن التهديدات لتحديد التهديدات السابقة التي لم تُرصد The Managed SOC Service Provider to implement threat detection for historical and near realtime threats based on the following: ● Signature-based and behavior-based detection to uncover anomalous and/or malicious activities ● Detect anomalies and outliers using statistical methods against established baselines ● Threat intelligence feeds to provide retro-matching capability		
٣٣	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على تطبيق علوم البيانات وطرق التعلم الآلي، بما في ذلك النماذج المخصصة، للكشف عن التهديدات المتقدمة وتصنيف الأحداث. The Managed SOC Service Provider to demonstrate capability to apply data science and machine learning methods, including custom models, for advanced threat detection and event classification.	مطلوب	موصى به
٣٤	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدرته على إنشاء وتنفيذ قواعد الكشف عن التهديدات وحالات الاستخدام المخصصة بما يتناسب معها وتحديثها باستمرار The Managed SOC Service Provider to demonstrate capability for creating and implementing custom detection rules and use cases and continuously update them.	مطلوب	موصى به
٣٥	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار دعم الاستيعاب الآلي لصيغ القواعد الشائعة حسب أفضل الممارسات في المجال، والتي تشمل على سبيل المثال لا الحصر، قواعد SIGMA وقواعد YARA، وتطبيق القواعد ضمن النظام المُخصص لها. The Managed SOC Service Provider to support automated ingestion of common rule formats according to best practices including but not limited to SIGMA and YARA, and natively executing rules.	مطلوب	موصى به
٣٦	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار ضمان التزود الآلي المستمر بالمعلومات الاستباقية من المصادر التجارية والمصادر المفتوحة والعامة، ومن القطاعات المحددة للجهات المستفيدة، ومن المجموعات المغلقة والشبكة المظلمة (Dark Web)، والالتزام التام بالمتطلبات التنظيمية الصادرة عن الهيئة فيما يتعلق بمشاركة معلومات الأمن السيبراني.	مطلوب	موصى به

الرقم	المتطلبات	المستوى الأول	المستوى الثاني
	The Managed SOC Service Provider to ensure continuous automated gathering of intelligence feeds from commercial sources, open and public sources, from specific industries and sectors, and the dark web; and to fully comply with regulatory requirements issued by NCA related to cybersecurity information sharing.		
٣٧	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار إثبات قدراته في مجال التحليل الآلي الكامل للبرمجيات الضارة (تقنية الحماية المعزولة - Sandboxing). The Managed SOC Service Provider to demonstrate capabilities for fully automated malware analysis using sandbox technologies.	مطلوب	مطلوب
٣٨	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار تطوير وتنفيذ برنامج لإدارة طاقته الاستيعابية، ليشمل صيانة ومراقبة وتقييم البنية التحتية الحالية للمركز والموظفين العاملين به وقدرات مقدم الخدمات بوجه عام ومعدل استخدامها ونسبة الاستفادة القصوى من الموارد، بهدف إدارة الطلب على الخدمات بشكل فعال وضمان قابلية التوسع في الخدمات. The Managed SOC Service Provider to develop and implement a capacity planning program including: maintenance, monitoring, and evaluating of current SOC infrastructure, personnel, and overall service provider capacity and utilization with a maximum cap on resource utilization, to effectively manage service demand and ensure scalability of services.	مطلوب؛ استخدام ٨٠٪ بحد أقصى	موصى به
٣٩	يجب على مقدم خدمة مركز عمليات الأمن السيبراني المُدار الالتزام بالمتطلبات التنظيمية للهيئة لبوابة حصين. The Managed SOC Service Provider to comply with regulatory requirements by NCA for Haseen portal.	مطلوب	مطلوب

١. أحكام عامة

١. يجب على مقدم الخدمة ضمان عدم تقديم أي توصيات لاحتواء التهديدات السيبرانية (Threat Containment Recommendations) أو الاستجابة للحوادث للجهات المستفيدة دون الحصول على موافقة خطية من الهيئة بذلك ووفقاً للمتطلبات التنظيمية التي تقرها الهيئة.
٢. للهيئة الحق في النظر إعفاء المرخص له من بعض المتطلبات الفنية وفقاً لتقديرها المطلق.
٣. للهيئة الحق بتعديل أي جزء من المتطلبات الفنية المنصوص عليها في هذه الوثيقة وفقاً لتقديرها المطلق وحاجة تنظيم الخدمات ذات الصلة.
٤. ستقوم الهيئة بالتحقق من التزام المرخص له بهذه المتطلبات ولها كافة الصلاحيات في ذلك ويتوجب على المرخص له تمكين الهيئة من إي إجراءات تحقق وتقييم ومتابعة لتحقيق ذلك.

٧. الملحق

الملحق (أ): عوامل التمكين الأساسية لقدرات خدمات مركز عمليات الأمن السيبراني المُدار

تتضمن خدمات مركز عمليات الأمن السيبراني المُدار ثلاث ركائز رئيسية تمثل عوامل التمكين الأساسية لكل خدمة من تلك الخدمات.

- العمليات
- التقنيات
- الأفراد

تنطوي كل ركيزة على عناصر محددة تتيح تقديم الخدمة وتساعد في ضمان جودتها. وتوضح الأقسام التالية المتطلبات على سبيل المثال لا الحصر لهذه العناصر. وفي حالة عدم النص صراحةً على ضرورة إلزام مقدمي الخدمات باستيفاء هذه المتطلبات، يوصى بشدة استيفائها لتقديم خدمات مركز عمليات الأمن السيبراني المُدار على النحو الواجب.

أ-١: العمليات

يوضح هذا القسم العمليات الرئيسية اللازم تطويرها من قبل مقدم الخدمة، علماً بأن هذه القائمة هي الحد الأدنى من العمليات، وقد يُطلب من مقدم الخدمة تطوير وتنفيذ عمليات إضافية بناءً على المتطلبات والقدرات المطلوبة لخدمات مركز عمليات الأمن السيبراني المُدار.

١. سياسة وإجراءات ومعايير استخدام الأصول التقنية وإيقاف استخدامها لدى الجهة المستفيدة
٢. سياسة وإجراءات ومعايير جرد الأصول واستخدامها وإيقاف استخدامها
٣. سياسة وإجراءات ومعايير جمع بيانات قياس أداء الشبكات
٤. سياسة وإجراءات ومعايير الاحتفاظ بالبيانات
٥. سياسة وإجراءات ومعايير النسخ الاحتياطي للبيانات والتخلص منها
٦. سياسة وإجراءات ومعايير هندسة الكشف عن التهديدات
٧. سياسة وإجراءات ومعايير إعداد الفرضيات
٨. إطار وسياسة وإجراءات ومعايير إدارة المعلومات الاستباقية عن التهديدات (بما في ذلك التجميع والترتيب والربط والتحليل والإنتاج)
٩. سياسة وإجراءات ومعايير دورة حياة تطوير البرمجيات الآمنة (SDLC)
١٠. عملية إصدار طلبات الدعم ومخططات سير العمل
١١. سياسة وإجراءات ومعايير إدارة التغيير
١٢. سياسة وإجراءات ومعايير إدارة حالات الاستخدام والكشف عن التهديدات
١٣. سياسة وإجراءات ومعايير إدارة المعرفة
١٤. عملية وسياسة وإجراءات ومعايير تسليم المناوبة
١٥. خطة وسياسة وإجراءات ومعايير الإبلاغ عن الحوادث وتصعيدها

١٦. إجراءات تقييم المخاطر (جمع البيانات والتحليل وإعداد التقارير)
١٧. خطة ونماذج الاستجابة للحوادث (الاحتواء، والتفادي، والتعافي، وأنشطة ما بعد الحادث، وإعداد التقارير)
١٨. أدلة استرشادية للاستجابة للحوادث السيبرانية
١٩. سياسة وعملية وإجراءات ومعايير جمع الأدلة
٢٠. سياسة وعملية وإجراءات ومعايير ضبط الأدلة
٢١. سياسة وعملية وإجراءات ومعايير الحفاظ على الأدلة
٢٢. سياسة وعملية وإجراءات ومعايير سلسلة العهدة
٢٣. سياسة وإجراءات ومعايير مراقبة الخدمات وإعداد التقارير بشأنها
٢٤. عمليات وسياسة وإجراءات ومعايير إدارة خدمات تقنية المعلومات
٢٥. سياسة وإجراءات ومعايير التصاريح الأمنية لموظفي مركز العمليات الأمنية
٢٦. سياسة وإجراءات ومعايير الوصول لمركز البيانات ومرافق مركز العمليات الأمنية

أ-٢: التقنيات

يتضمن هذا القسم قائمة بالحد الأدنى من التقنيات الرئيسية ذات العلاقة التي تدعم خدمة مركز عمليات الأمن السيبراني المُدار:

١. استكشاف وإدارة الأصول
٢. تقنيات لجمع سجلات الأحداث الخاصة بالأمن السيبراني (SIEM)
٣. الكشف عن التهديدات على الأجهزة الطرفية والاستجابة لها (EDR)
٤. الكشف عن التهديدات على الشبكات والاستجابة لها (NDR)
٥. الحماية من التهديدات المتقدمة (APT)
٦. تحليل سلوكيات المستخدمين والعناصر (UEBA)
٧. التحليل باستخدام الذكاء الاصطناعي والتعلم الآلي
٨. العرض المرئي للبيانات
٩. الاشتراك بمصادر المعلومات الاستباقية عن التهديدات (TIP)
١٠. أدوات تحليل البرمجيات الضارة (Malware Sandboxing)
١١. احتواء التهديدات (Threat Containment)
١٢. إدارة الحالات (Case Management)
١٣. التنسيق الأمني والأتمتة والاستجابة (SOAR)
١٤. إدارة الأدلة الرقمية

أ-٣: الأفراد

ستمّنح الهيئة شهادات تأهيل من ثلاثة فئات للأفراد الذين سيعملون كمحلّين في مراكز عمليات الأمن السيبراني المُدارة، ويجب على هؤلاء الأفراد تلبية الحد الأدنى من متطلبات الحصول على شهادة التأهيل وفقاً للمنصوص عليه في الإطار التنظيمي لترخيص تقديم خدمات مركز عمليات الأمن السيبراني المُدار.

الملحق (ب): متطلبات سمات سجلات الأحداث

تحدد المتطلبات التالية أبرز السمات التي يجب أن توفرها سجلات الأحداث السيبرانية، بحسب ما ينطبق على نوع سجل الأحداث:

١. سمات التسجيل

- ١) **النوع:** نوع الحدث الذي وقع والتفاصيل المتعلقة به (مثل: حجم البيانات)
- ٢) **المكان:** مصدر الحدث (المصدر والوجهة وتفاصيل البروتوكول)
- ٣) **الطرف المعني:** تحديد النظام والمستخدم والجهاز المرتبط بالحدث
- ٤) **الوقت:** وقت وقوع الحدث (أي التاريخ والختم الزمني)
- ٥) **النتيجة:** نجاح أو فشل الحدث

٢. بيانات سجل الأحداث

- المعرف الفريد للحدث
- الصيغة المناسبة والدقيقة للختم الزمني: (GMT+<>) YYYY-MM-DDThh:mm:ss.mmm
- رمز حالة نوع الحدث
- معرف الجهاز
- معرف الجلسة / المعاملة
- رقم النظام المستقل
- بروتوكول الإنترنت المصدر (الإصدار الرابع من بروتوكول الإنترنت "IPv4")
- بروتوكول الإنترنت المصدر (الإصدار السادس من بروتوكول الإنترنت "IPv6")
- المَنفذ المصدر
- بروتوكول الإنترنت المستهدف (الإصدار الرابع من بروتوكول الإنترنت "IPv4")
- بروتوكول الإنترنت المستهدف (الإصدار السادس من بروتوكول الإنترنت "IPv6")
- المَنفذ المستهدف
- معرف التطبيق
- رمز الحالة
- وقت الاستجابة
- خانات إضافية
- اسم المستخدم ومعرف المستخدم
- الأمر المُنفذ
- حجم الحزمة/البيانات

الملحق (ج): الحد الأدنى من متطلبات جمع بيانات الأحداث السيبرانية

تحدد المتطلبات التالية الحد الأدنى من سجلات الأحداث اللازم جمعها وتوظيفها في عملية المراقبة والاكتشاف. كما يتوجب على مقدم الخدمة جمع وتوظيف سجلات الأحداث الخاصة بقواعد الاكتشاف التي يتم تطويرها من قبله، أو تلك المبنية على مصادر المعلومات الاستباقية التي يشار إليها من قبل الهيئة.

تصنيف السجل	البيانات المطلوبة	الصيغة	مدة الحفظ
Identity Management	Identity Management - Account Creation - Credential Type - Establish/Manage Attributes - Organization - Groups/Roles - Manage/Track Changes in Attributes & Credentials - Track Usage of Credentials - Account Deletion	Log Script	12 Months Active Storage 18 Months Cold Data Storage
Privileged Identity Management	Privileged Identity Management - Provisioning - Credential Type - Establish/Manage Attributes - Organization - Groups/Roles - Manage/Track Changes in Attributes & Credentials - Track Usage of Credentials - Deprovisioning - Establish and Manage Privileges (Privilege Credentials) - Isolate, Monitor, Record, Audit Privilege Sessions - Control Privileged Actions - Commands - Tasks - Track Privilege Escalation and Delegation Monitor, Alert and Respond to Anomalous Behaviors/Activities	Log Script	12 Months Active Storage 18 Months Cold Data Storage

12 Months 18 Months Cold Data Storage	Log	Email header, IP and Domain	Email Filtering, Spam, and Phishing
12 Months Active Storage 18 Months Cold Data Storage	Log	All Devices - DHCP Lease Information Including: - MAC - IP	Network Device Infrastructure
12 Months Active Storage 18 Months Cold Data Storage	Log	DNS Records- Source IP and Port, Destination IP and Port Date and Time - Content of Query, Response, and Errors – All Record Types - Zone Transfers Request and Response (Audit Log) - Zone Transfers Request and Response (Content) Passive DNS Log - Tuple (Rrname, Rrtype, Rdata) - Time_First - Time_Last - Count - Origin - Count of Questions Asked by Source IP - Count of Questions Asked Overall - Count of Responses by Source IP - Query Size in Bytes - Response Size in Bytes	Network Device Infrastructure

12 Months Active Storage	Log SNMP	DHCP, and Wi-Fi • Wi-Fi Supporting Infrastructure Logs Including Security Logs at Info Level • Device Authentication Logs with User Agent • URL Browsing Logs + HTTP Methods (e.g., Post, Get, etc.) • User Authentication Logs • DHCP Lease Information Including MAC, IP	Network Device Infrastructure
18 Months Cold Data Storage			
12 Months Active Storage	Log	DNS, DHCP, and Wi-Fi • Static Network Address Translation Table Mapping as Well as Port Forwards: ○ Date and Time ○ Protocol ○ Port ○ IP mapping	Network Device Infrastructure
18 Months Cold Data Storage	Config		
12 Months Active Storage	Log	• IDS / IPS / NDR Logs • API Activity Logs • Authentication Logs • Firewall Logs • Web Proxy/WAF Logs • Network Flow Logs • Remote Access/VPN Logs • DLP Logs • DNS Query/Response Logs	Network Device Infrastructure (General Logging)
18 Months Cold Data Storage	File		
72 Hours Packet Capture	Packet Capture		
12 Months Active Storage	Script	Routers and Switches • Routing Tables • Routing Changes (Logging All CLI Commands, BGP) • IP Addressing Schema and Implementation • Authentication Logs	Network Device Infrastructure
18 Months Cold Data Storage	File		
12 Months Active Storage	Config		
18 Months Cold Data Storage			
12 Months Active Storage	Log	Load Balancer / Reverse Proxy Access Logs • Connection Type • Date and Time • Resource ID of the Load Balancer • Client IP:Port • Target IP:Port • X-Forwarded-For	Network Device Infrastructure
18 Months Cold Data Storage			

		● Request Processing Time ● Target Processing Time ● Response Processing Time ● Status Code from Load Balancer ● Target Status Code ● Received Bytes ● Bytes Sent ● Request ● User Agent ● SSL Protocol ● Matched Rule Priority ● Actions Executed ● Redirect URL ● Error Reason ● Target IP:Port List ● Target Status Code List	
12 Months Active Storage 18 Months Cold Data Storage	Log	Proxies and Web Content Filters Provides NAT, User, and Gateway IP Address to Provide Enhanced Reporting of Malicious Domains and IP Addresses. In the Case of Web, W3c Format. ● Date and Time ● Source ○ Hostname ○ IP Address and Port ○ MAC ● Destination ○ Hostname ○ IP Address and Port ○ MAC ● Web URL Methods / User Agent / Decoded Headers ● URL Categories ● URL Permitted, Restricted, Denied	Network Device Infrastructure

12 Months Active Storage	Log	General Information • Date and Time • Event, Status, or Error Codes • Service/Command/Application Name • User or System Account Associated with an Event • Device Used (e.g., Source and Destination IPs, Terminal Session ID, Web Browser, etc.) Operating System (OS) Events • Start-Up and Shutdown of the System • Start-Up and Shutdown of a Service • Network Connection Changes or Failures • Changes to, or attempts to Change, System Security Settings and Controls OS Audit Records • Log-On Attempts (Success/Failure) • The Function(s) Performed after Logging On (e.g., Reading or Updating a Critical File, Software Installation) • Account Changes (e.g., Account Creation and Deletion, Account Privilege Assignment) • Successful/Failed Use of Privileged Accounts • Command-line actions • Process execution Application Account Information • Application Authentication Attempts (Success/Failure) • Application Account Changes (e.g., Account Creation and Deletion, Account Privilege Assignment) • Use of Application Privileges Application Operations • Application Startup and Shutdown • Application Failures • Major Application Configuration Changes • Application Transactions, For Example ○ Email Servers Recording the Sender, Recipients, Subject Name, and Attachment Names for Each Email	Network Device Infrastructure (Access, Authorization, and Accounting)
18 Months Cold Data Storage			

		○ Web Servers Recording Each URL Requested and the Type of Response Provided by the Server ○ Business Applications Recording Which Financial Records Were Accessed by Each User	
12 Months Active Storage 18 Months Cold Data Storage	Log	User and Administrator Access to OS Components and Applications ● File and Object Access ● Audit Log Access (Success/Failure) ● System Access and Log Off (Success/Failure) ● Privilege Access and Log Off (Success/Failure) ● RDP Access and Log Off (Success/Failure) ● SMB Access ● Installation or Removal of Storage Volumes or Removeable Media System Performance and Operational Characteristics ● Resource Utilization, Process Status ● System Events ● Service Status Changes (Start, Stop, Fail, Restart, etc.) ● Service Failures and Restarts ● Process Creation and Termination System Configuration ● Changes to Security Configuration (Success/Failure) ● Audit Log Cleared ● Changes to Accounts ● User or Group Management Changes ● Scheduled Task Changes File Access ● Transfer of Data to External Media or Remote Hosts Host Network Communications ● Listening Network Port and IP Address ● Active Network Communication with Other Hosts PowerShell Execution Commands WMI Events Registry Access	Operating Systems - Windows Infrastructure and Operating Systems

		Command-Line Interface (CLI) Basic Input Output System (BIOS), Unified Extensible Firmware Interface (UEFI), and Other Firmware • Version • Created Date • Installed Date Manufacturer	
12 Months Active Storage 18 Months Cold Data Storage	Log	User and Administrator Access to OS Components and Applications • File and Object Access • Audit Log Access (Success/Failure) • System Access and Log Off (Success/Failure) • Privilege Access and Log Off (Success/Failure) • Remote Terminal or Equivalent • Access and Log Off (Success/Failure) • Samba/NFS/(S)FTP or Equivalent Access • Installation or Removal of Storage Volumes or Removeable Media System Performance and Operational Characteristics • Resource Utilization, Process Status • System Events • Service Status Changes (Start, Stop, Fail, Restart, Etc.) • Service Failures and Restarts • Process Creation and Termination System Configuration • Changes to Security Configuration (Success/Failure) • Audit Log Cleared • Changes to Accounts • User or Group Management Changes • Scheduled Task Changes File Access • Transfer of Data to External Media or Remote Hosts Host Network Communications • Listening Network Port and IP Address • Active Network Communication with Other Hosts Command-Line Interface (CLI)	Operating Systems – BSD (Linux)

		Security Enhanced Linux (SELinux) AppArmor or Equivalent • Warning Logs • Violation Logs System • /Var/Log/Messages • /Var/Log/Dmesg • /Var/Log/Syslog • /Var/Log/Daemon.Log • /Var/Log/Cron • /Var/Log/Kern.Log • /Var/Log/Boot.Log Access And Authentication • /Var/Log/Auth.Log • /Var/Log/Secure • /Var/Log/Faillog • /Var/Log/Btmp • /Var/Log/Wtmp or /Var/Log/Utmp Applications • /Var/Log/Mail.Log or /Var/Log/Maillog • /Var/Log/Xorg.X.Log Package Install/Uninstall • /Var/Log/Dpkg.Log • /Var/Log/Yum.Log Basic Input Output System (BIOS), Unified Extensible Firmware Interface (UEFI), and Other Firmware • Version • Created Date • Installed Date • Manufacturer	
12 Months Active Storage 18 Months Cold Data Storage	Log	• Any Activity on Breakglass Account(s) • Conditional Access Policy Changes • Changes to Environment Policies in Management Logs • Privileged Role Changes • Virtual Network (VNet) Changes • Deletions of Delete Locks • Changes to Logging Policies	Cloud Environments (General Events)

		- Privileged Identity Management (PIM) and Identity Protection Changes - Changes to Alert Rules (Audit the Auditor) - Key Vault/Key Management Changes - Storage File Access Logs, File, File Hashes - Baseline Deviations for Prod App Tiers	
12 Months Active Storage 18 Months Cold Data Storage 72 Hours Packet Capture	Log	- IDS / IPS / NTA / NDR / SIEM Logs - API Activity Logs - Authentication Logs - Firewall Logs - Web Proxy/WAF Logs - Service Metrics - Billing Data - Flow Logs - Remote Access/VPN Logs - System/OS Logs - DLP Logs - DNS Query/Response Logs	Cloud Environments (General Logging)
12 Months Active Storage 18 Months Cold Data Storage	Log	Configuration Changes - Management Action (Success/Failure) - Admin Login (Success/Failure)	System Configuration and Performance

12 Months Active Storage	Log	Administrative ● Authentication Logons (Success/Failure) ● Authentication Logoffs ● Privilege Elevation (Success/Failure) ● Security Related System Alerts and Failures ● User and Group ○ Additions ○ Deletions ○ Modification to Permissions ● Unauthorized Access Attempts to Critical Systems and File	Authentication and Authorization
12 Months Active Storage	Log	Authorization All Privileged Operations Including: ● “sudo” or runas ● Enabling CLI Access ● System Administrative Commands ● Powershell Execution Commands ● Powershell Script Block Logging	Authentication and Authorization
12 Months Active Storage	Log Email Attachments	Anti-virus and Behavior-based protection ● Date and Time ● Source Hostname ○ IP ○ Port ● Destination Hostname ○ IP ○ Port ● Description of Malicious Code or Action and Severity ● Identity or (Hash) Identifier of the File(s) ● Description of the Action Taken (Clean, Quarantine, Delete) ● Signature Updates Indication of the Host that Connected to a Specific URL ● Date and Time ● IP and Domain Reputation ● URL Categorization Endpoint Detection & Response (EDR)	Endpoint Security Tools
18 Months Cold Data Storage			

12 Months Active Storage	Log	Firewalls All Events from Firewall. At the very least, if access control lists (ACL) are enabled and the device is filtering traffic: ● Action Permit, Teardowns and Closes ● Interface ● Source ○ Hostname ○ IP Address and Port ○ MAC ● Destination ○ Hostname ○ IP Address and Port ○ MAC ● Protocol Type ● Rule Name and Number Triggered ● URL if Applicable, Associated User and User Agent Date and Time	Network Device Infrastructure
12 Months Active Storage	Log	All Devices: IDS / IPS Alerts and Events ● Date and Time ● Source ○ Hostname ○ IP Address and Port ○ MAC ● Destination ○ Hostname ○ IP Address and Port ○ MAC ● Signature Triggered and Associated Details Including: ○ Signature ○ Anomaly ● Rate Threshold ● Device Name ● Type of Event and Category ● In the Case of Fortinet Network IPs, Attack Context ● (Web / Device) User Agent if Available ● Wi-Fi Channel ● Wi-Fi Extended Service Set Identifier (ESSID)	Network Device Infrastructure

12 Months Active Storage 18 Months Cold Data Storage	Log	VPN Gateway – All Events At the very least, for Accepts, Teardowns, Closes, Denies, and Drops: • Date and Time • Source ○ Hostname ○ IP Address and Port ○ MAC • Port MAC • Destination ○ Hostname ○ IP Address and Port ○ MAC • Source IP Address and Port, MAC (Inside Tunnel) • Destination IP Address and Port, MAC (Inside Tunnel) • Authentication Information (Success/Fail with Username and Device with User Agent) • Change in Status of Connections / Tunnel Status • VPN Certificate Status Validation •	Network Device Infrastructure
12 Months Active Storage 18 Months Cold Data Storage	Log Database Query	• Addition of New Users, Especially Privileged Users • Query Being Executed • Query, Status (Response), and Traceback ○ Method ○ Comments or Variables ○ Multiple Embedded Queries ○ Database Alerts or Failures ○ Time to Execute Query • Attempts to Elevate Privileges (Success/Failure) • Changes to the Database Structure • Changes to User Roles or Database Permissions • Database Administrator Actions • Database Logons (Success/Failure) • Failed Logons • Use of Executable Commands • CLI Commands against the Data Base	Database Level

		- Database Configuration and Version - Access to Sensitive Information within the Databases such as Keys, Passwords, Privacy Related Data	
12 Months Active Storage 18 Months Cold Data Storage	Log Log and PCAP of Plaintext HTTP Request and Response with Data	Web Application Crashes - Processes - Applications Web Applications & Middleware - Configuration Version	Application Level
72 Hours Packet Capture	Packet Capture	Full Packet Capture Data - Decrypted Plaintext - Cleartext	Network Traffic
12 Months Active Storage 18 Months Cold Data Storage 72 Hours Packet Capture	Log Application Monitoring Dashboards Log of Plaintext HTTP Request and Response with Data	Web Applications - URL - Headers - HTTP Methods - Request with Body of Data - HTTP Response with Body of Data Web Application Databases - Database Queries - Response Codes Web Applications - User Authentication (Success/Failure) - User and Administrator Application Use: - File and Object Access - Audit Log Access (Success/Failure) - System Access (Failure)	Application Level

		○ Application Transactions (Web Page Hits, Email Sent/Received, File Transfers Completed) ● Transaction Logs ● System Performance and Operational Characteristic ○ Resource Utilization ○ Process Status ○ Errors (Input Validation, Dis-Allowed Operations) ○ System Events ○ Service Status Changes (e.g., Started, Stopped) ● Application Configuration and Version	
--	--	---	--

*يمكن لمقدم الخدمة زيادة مدة حفظ السجلات بالاتفاق مع الجهة، حيث تعد المدة المحددة في هذه الملحق الحد الأدنى

